Web Application Scan on DVWA

Objective: Use Nessus Essentials to scan an intentionally vulnerable web application hosted in the lab, then analyse the results.

Background

Before attackers find the weaknesses in a web application, it is the defender's job to discover them first. In this task, Nessus Essentials with the Web Application Tests template is used to scan DVWA (Damn Vulnerable Web Application), an intentionally vulnerable application installed on an Ubuntu Server VM.

Lab Information

Field	Value
Scanner	Nessus Essentials on Kali Linux (192.168.56.10)
Target	DVWA on Ubuntu Server (192.168.56.20)
Target URL	http://192.168.56.20/dvwa
Nessus Template	Web Application Tests

Section 1 – Preparing DVWA

Steps

1. Opened the web browser on Kali Linux.
2. Navigated to `http://192.168.56.20/dvwa`.
3. Logged in with the default credentials (`admin` / `password`).
4. Initialized / reset the DVWA database.
5. Logged in again after the reset.
6. Set the DVWA security level to **Low**.

Observations: The DVWA dashboard loaded successfully. The page confirms "Security level set to low" and the footer shows *Security Level: low*.

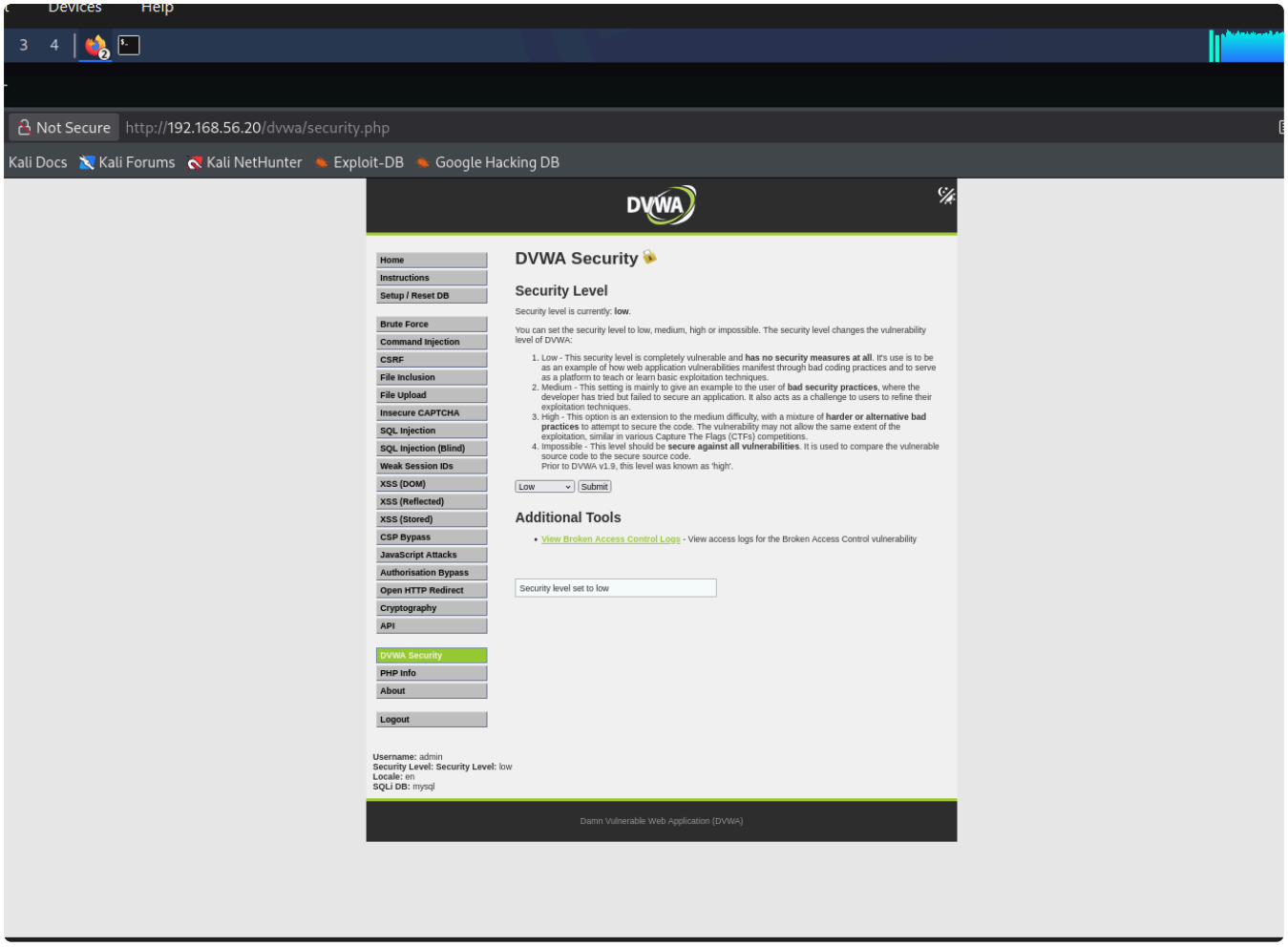


Figure 1 – DVWA Security page with the security level set to low.

Section 2 – Scan Configuration

Steps in Nessus

1. Opened the Nessus web interface at `https://localhost:8834`.
2. Clicked **New Scan**.
3. Selected the **Web Application Tests** template.
4. Configured the scan settings (name, target, discovery, assessment).
5. Configured HTTP cookie authentication in the Credentials tab, so the scanner could reach and crawl the logged-in application.

Scan Settings Record

Setting	Value
Scan Name	dwa
Target	192.168.56.20

Setting	Value
Scan Type	Web Application Tests
Port Range	80
Crawl start page	/dwa
Excluded pages (regex)	/server_privileges.php|logout
Max pages / depth	1000 pages / depth 6
Authentication	HTTP cookies import (dwacookie.txt)

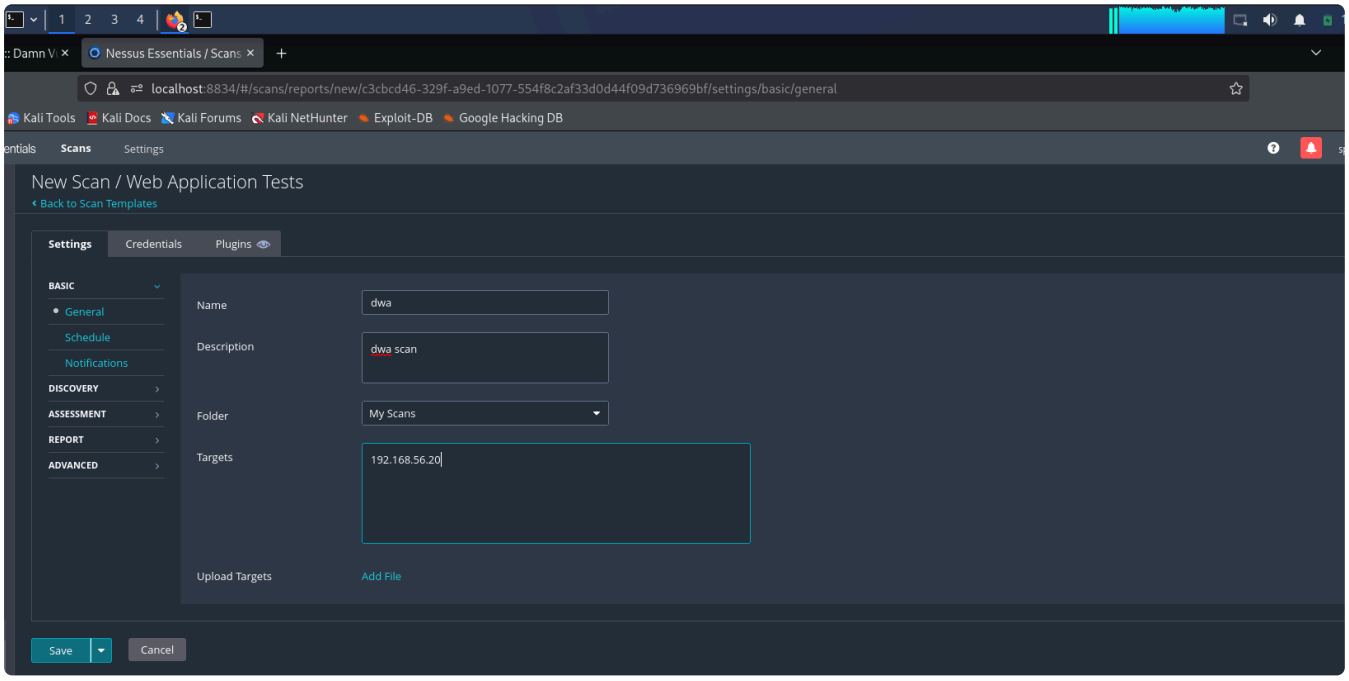


Figure 2 – Basic > General: scan name and target 192.168.56.20.

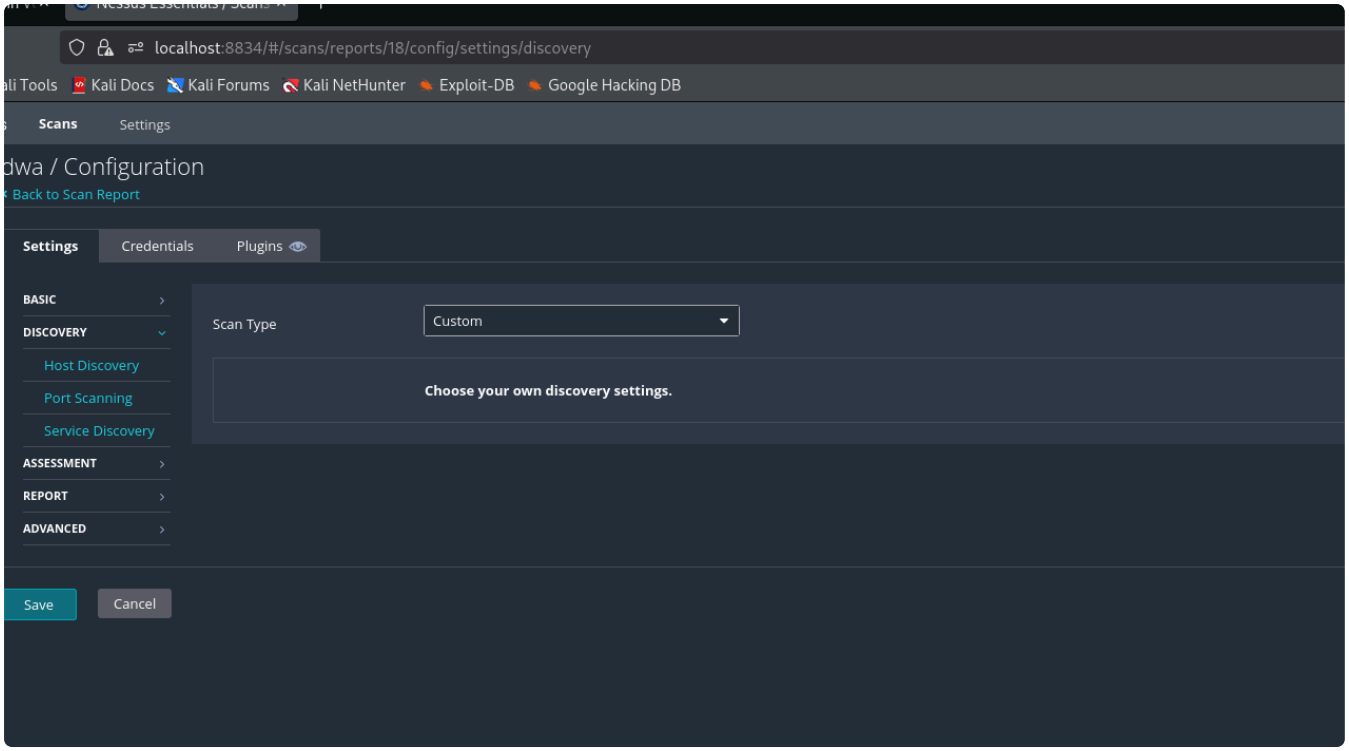


Figure 3 – Discovery settings (custom).

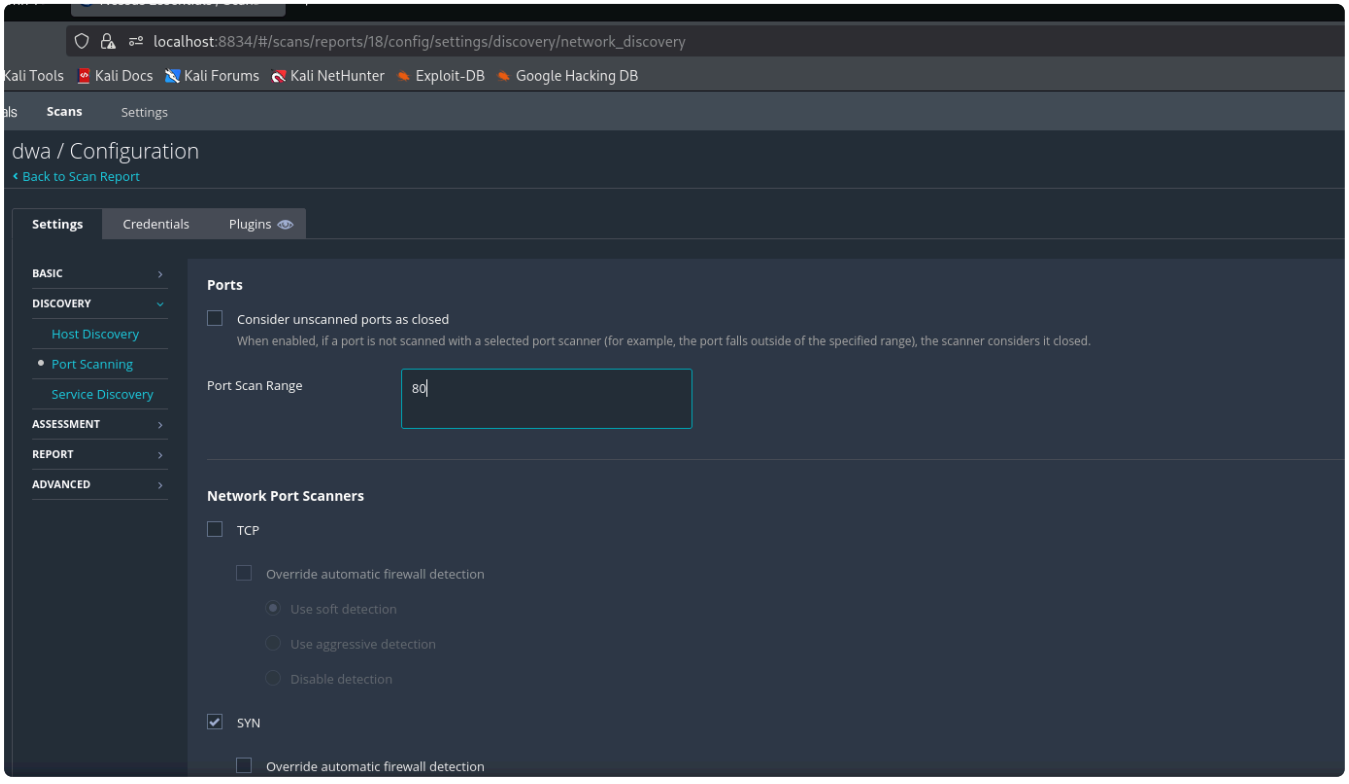


Figure 4 – Port scan range limited to port 80.

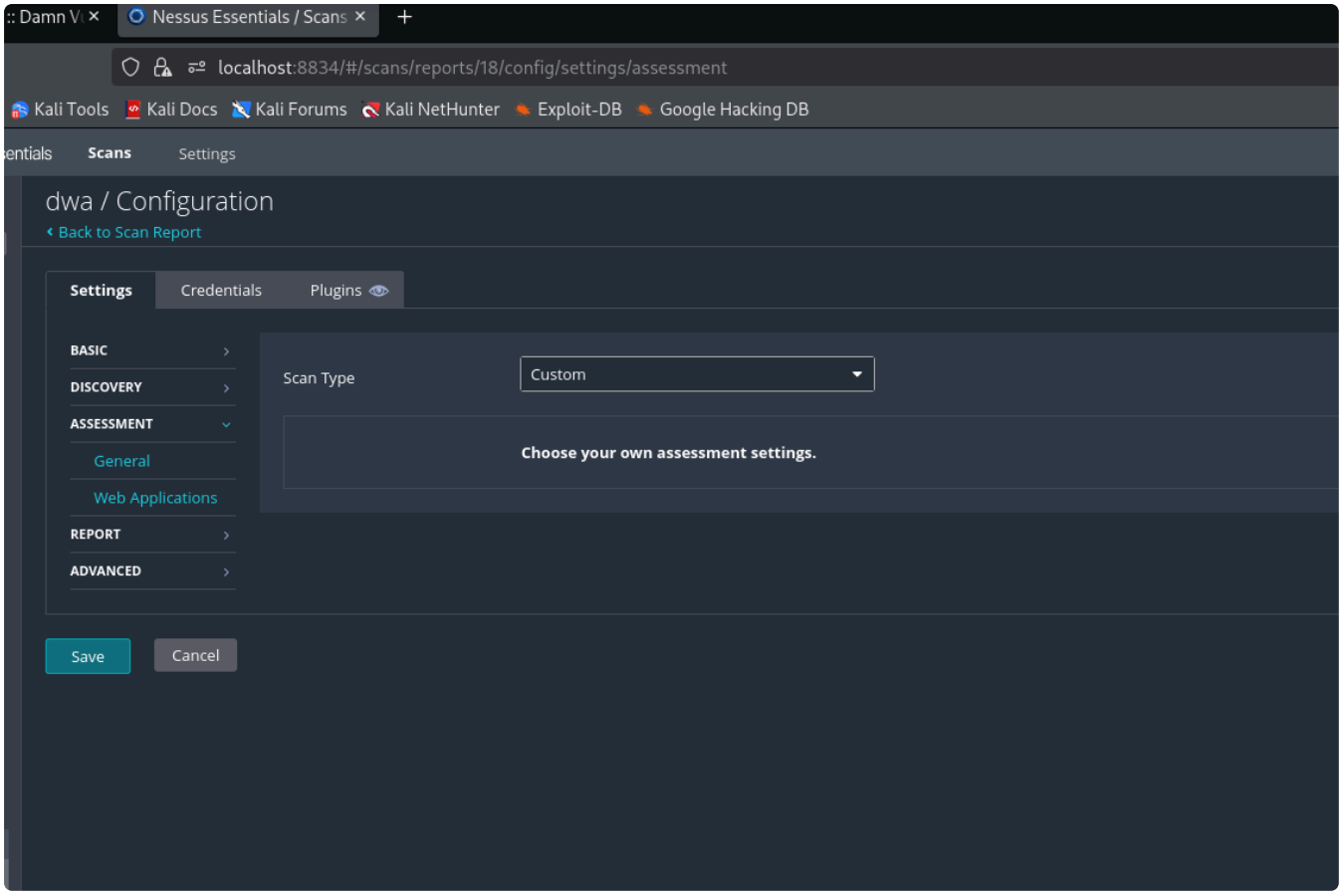


Figure 5 – Assessment settings (custom).

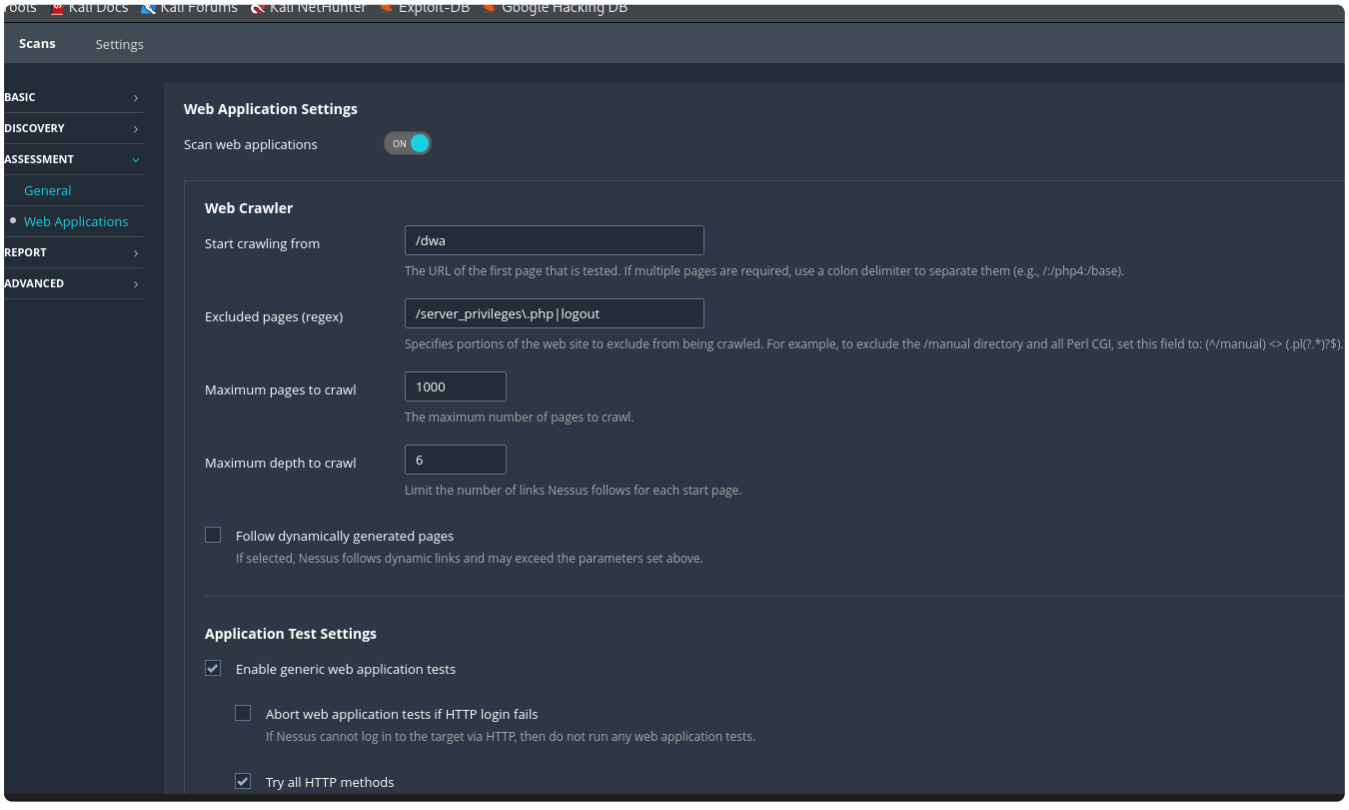


Figure 6 – Web Applications settings: crawler and application test options.

The session cookie (PHPSESSID, plus `security=low`) was taken from the browser's developer tools and saved in Netscape cookies.txt format for import.

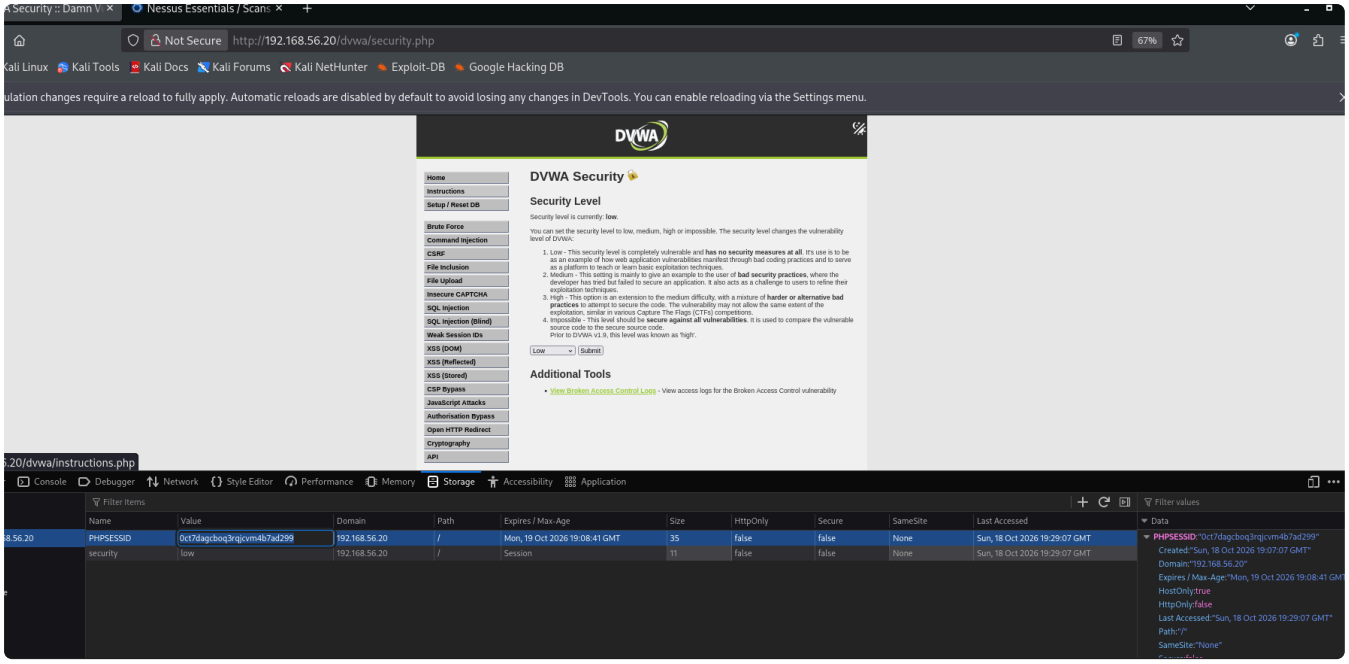


Figure 7 – DVWA session cookie (PHPSESSID) in browser storage.

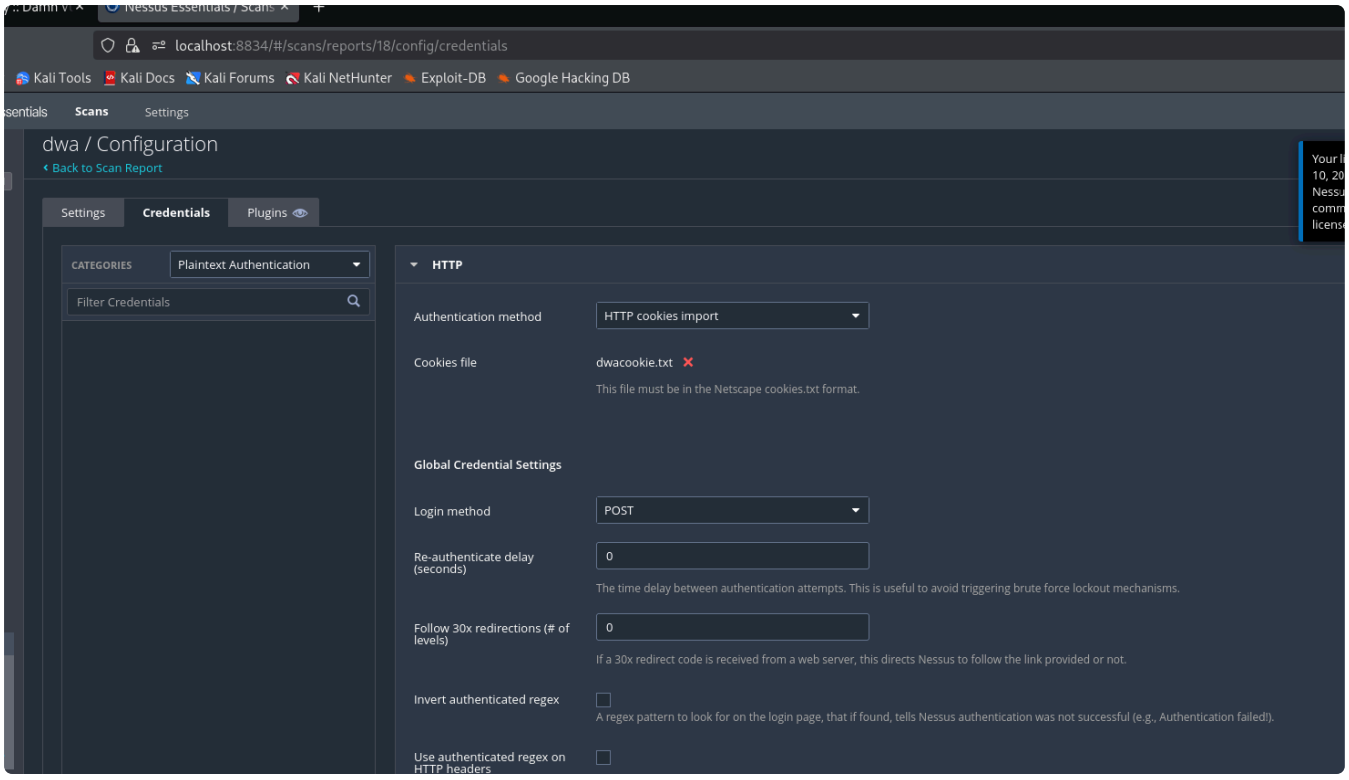


Figure 8 – Credentials tab: HTTP cookies import with dwacookie.txt.

Section 3 – Scan Execution

Steps

1. Launched the scan.
2. Monitored progress in the Nessus **Scans** view.
3. Waited until the status changed to **Completed**.

Scan Monitoring Record

Metric	Value
Start Time	Today at 3:56 PM
End Time	Today at 4:18 PM
Duration	22 minutes
Status	Completed

Note: the running-status screenshot (3% at 3:37 PM) comes from an earlier launch of the same scan; the History tab shows two runs.

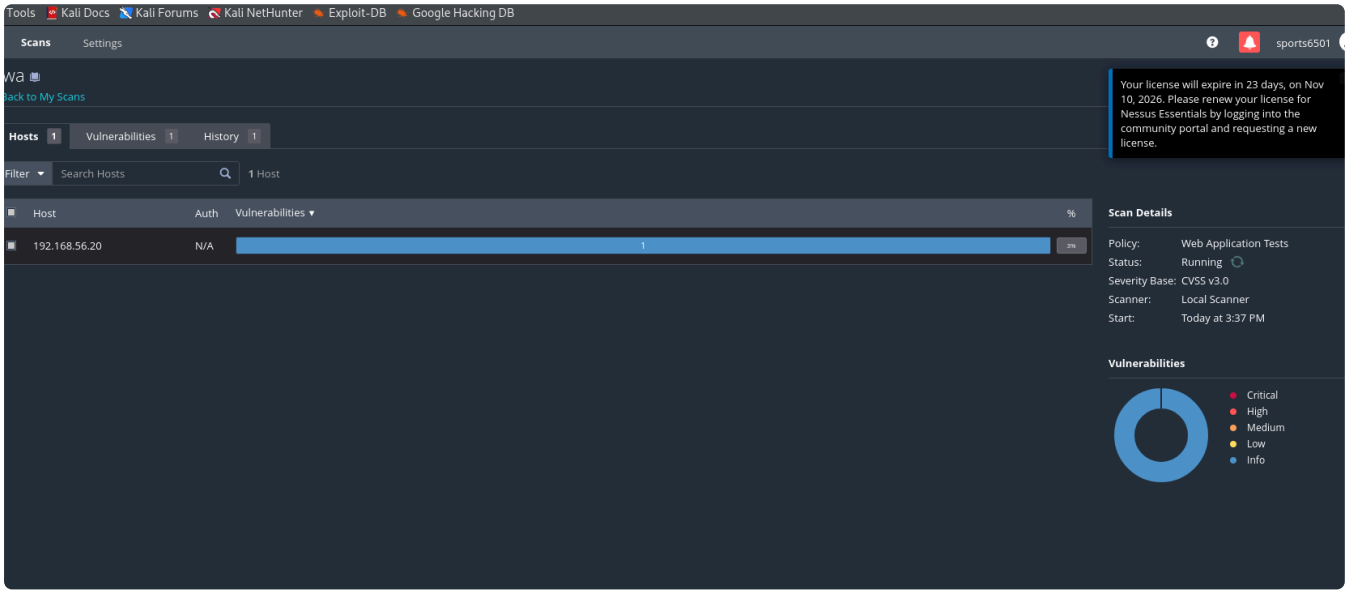


Figure 9 – Scan status: Running (3%).

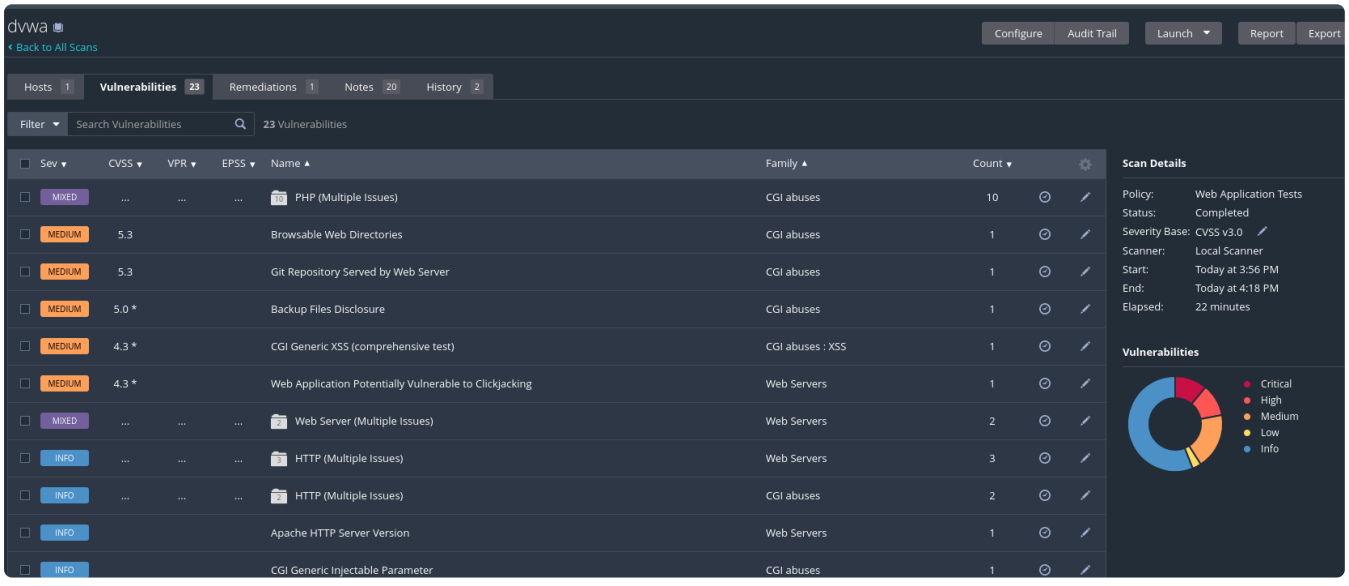


Figure 10 – Scan status: Completed (start 3:56 PM, end 4:18 PM, 22 minutes).

Section 4 – Results Analysis

4.1 Vulnerability Overview

The host view shows 36 individual findings, which Nessus groups into 23 entries in the Vulnerabilities tab (for example, 10 PHP findings are grouped under "PHP (Multiple Issues)").

Severity	Count
Critical	4
High	4
Medium	7
Low	1
Informational	20
Total	**36**

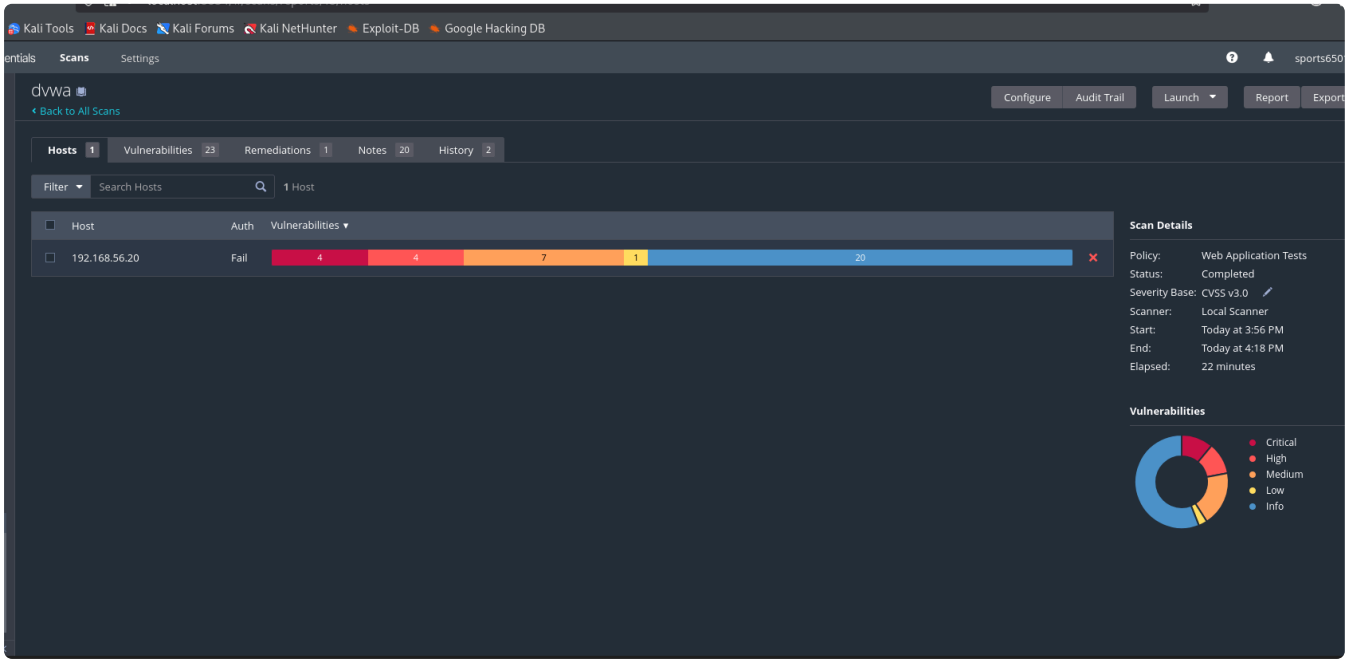


Figure 11 – Host 192.168.56.20: 4 Critical, 4 High, 7 Medium, 1 Low, 20 Info. The Auth column shows "Fail", meaning Nessus did not confirm the cookie-based login.

4.2 Critical and High Vulnerabilities

#	Vulnerability Name	Severity	CVSS v3	Service
1	PHP 8.3.x < 8.3.14 Multiple Vulnerabilities	Critical	9.8	http (80/tcp)

#	Vulnerability Name	Severity	CVSS v3	Service
2	PHP 8.3.x < 8.3.31 Multiple Vulnerabilities	Critical	9.8	http (80/tcp)
3	PHP 8.3.x < 8.3.33 Multiple Vulnerabilities SQLI	Critical	9.8	http (80/tcp)
4	PHP 8.3.x < 8.3.8 Multiple Vulnerabilities	Critical	9.8	http (80/tcp)
5	PHP 8.3.x < 8.3.12 Multiple Vulnerabilities	High	8.8	http (80/tcp)
6	PHP 8.3.x < 8.3.29 Multiple Vulnerabilities	High	8.2	http (80/tcp)
7	PHP 8.3.x < 8.3.19 Multiple Vulnerabilities	High	7.5	http (80/tcp)
8	PHP 8.3.x < 8.3.23 Multiple Vulnerabilities	High	7.5	http (80/tcp)

All eight findings come from the same root cause: the server runs an outdated PHP 8.3.6.

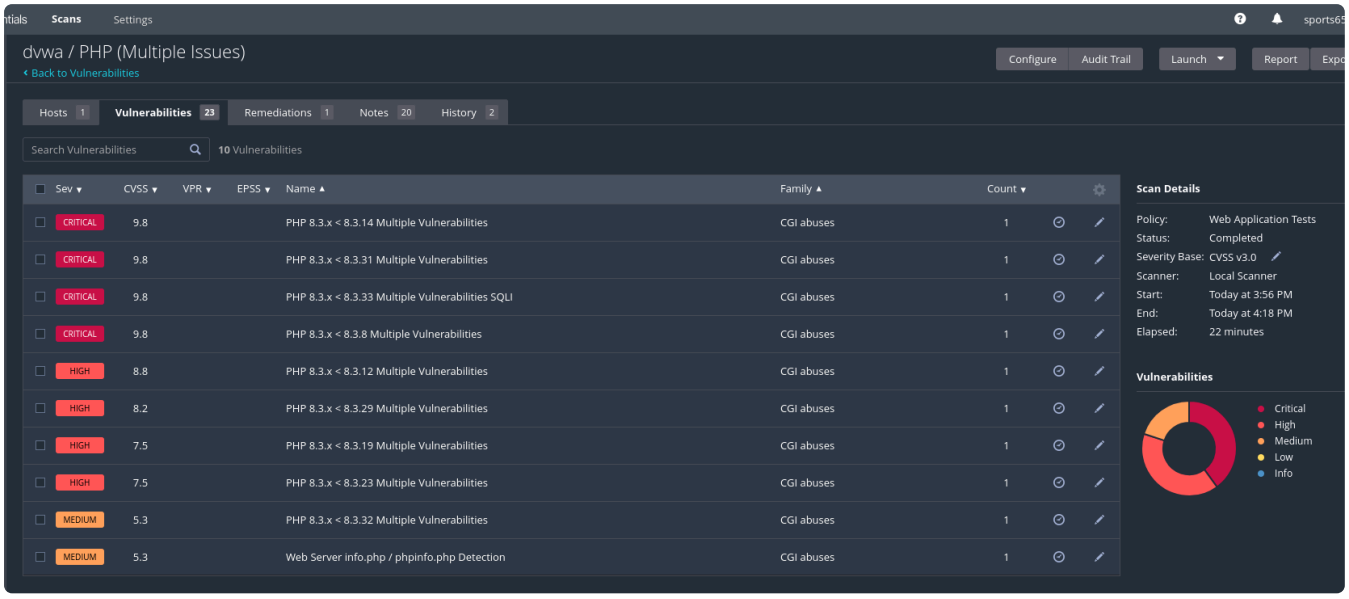


Figure 12 – PHP (Multiple Issues) group: Critical and High findings.

4.3 Deep Dive – One Vulnerability

Field	Detail
Plugin Name	PHP 8.3.x < 8.3.14 Multiple Vulnerabilities
Plugin ID	211670
CVE ID	None listed on the plugin page (see the GitHub security advisories under See Also)
Plugin Family	CGI abuses
Severity	Critical

Field	Detail
CVSS v3.0 Base Score	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Affected Host	192.168.56.20
Port / Service	80 / http
Installed / Fixed version	8.3.6 / 8.3.14
Description	The installed PHP version is prior to 8.3.14 and is affected by multiple vulnerabilities. Nessus did not test the issues; it relied only on the application's self-reported version number.
Impact	A remote attacker could potentially execute arbitrary code, bypass security restrictions or cause a denial of service, depending on the specific flaw exploited.
Remediation	Upgrade to PHP 8.3.14 or later (ideally the latest 8.3.x release, which also covers the other findings).
References	https://php.net/ChangeLog-8.php#8.3.14

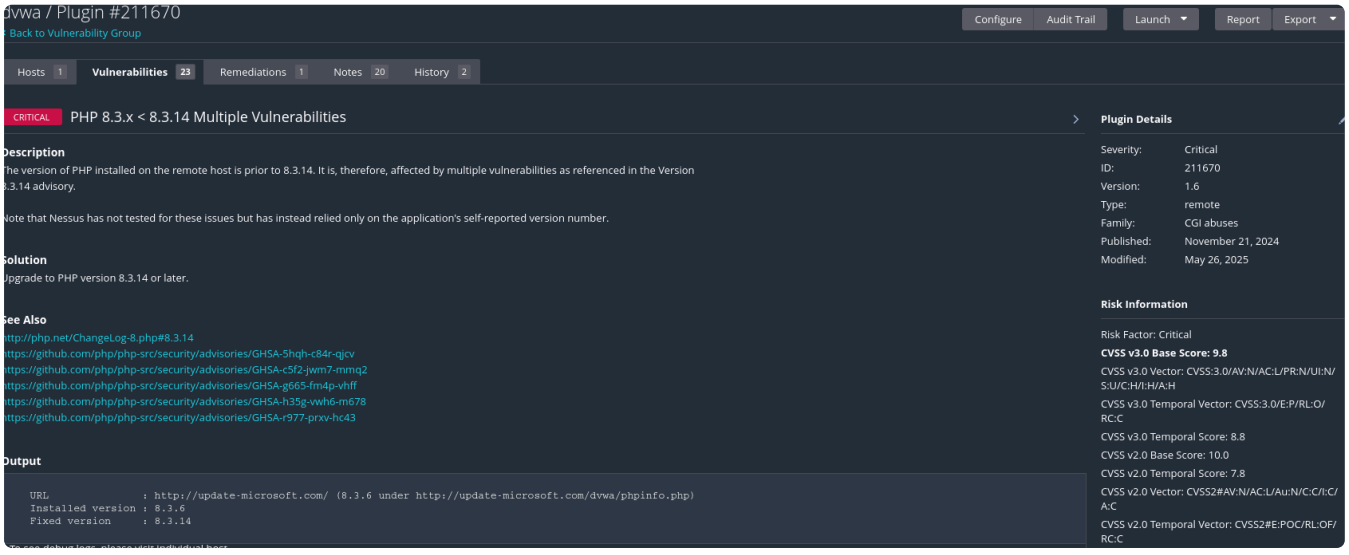


Figure 13 – Plugin #211670 detail page.

Section 5 – Report Export

Result: The export failed. A popup stated: "Exports are not available in Essentials. Upgrade to Nessus Professional to enable this feature."

Reason: Nessus Essentials does not support exporting scan reports to PDF or HTML, so results are documented with screenshots instead.

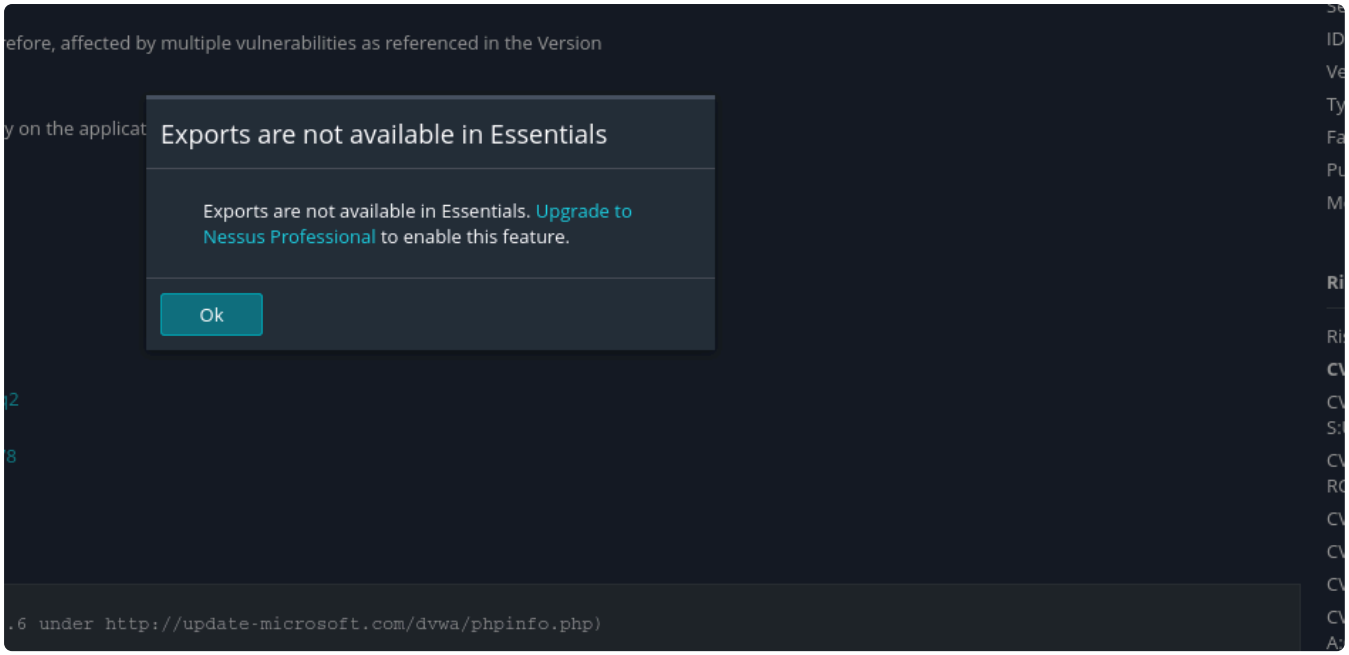


Figure 14 – Export blocked in Nessus Essentials.

Section 6 – Key Takeaway

Nessus found infrastructure-level problems, most importantly an outdated and vulnerable PHP version (8.3.6) that would expose the server to remote code execution in a real-world scenario. It also reported several web-level issues: a CGI Generic XSS finding, a git repository served by the web server, backup file disclosure, browsable directories, an exposed phpinfo.php page, and clickjacking exposure. It did not enumerate the full range of DVWA's classic flaws (such as SQL injection in each module), because Nessus is primarily a vulnerability scanner and its web tests are shallow compared with dedicated DAST tools such as Burp Suite or OWASP ZAP. The "Auth: Fail" status also suggests the authenticated crawl was limited. A complete assessment would combine Nessus with a DAST tool and a verified authenticated scan.

Submission Checklist

Item	Status
DVWA prepared and accessible	✅ Complete
Scan configured	✅ Complete
Scan executed successfully	✅ Complete
Scan monitoring data completed	✅ Complete
Vulnerability summary filled	✅ Complete

Item	Status
Critical/High table completed	✅ Complete
Deep dive section completed	✅ Complete
Nessus report exported (PDF)	⚠️ Not available in Essentials – documented with screenshots
All required screenshots included	✅ Complete